LAB 5 - VF-1D-A-696: SBOM / CVE / Patch

Çıktı: Zafiyet kararı (Vulnerability Decision); Evidence Pack EP 09, 10 ve 11.

Kavramlar

SBOM, yazılım malzeme listesidir. CVE, açığın kayıt numarasıdır. CVSS, ciddiyet puanıdır (0-10). Etkilenme için bileşenin bulunması, sürümün açık kapsamında olması ve açığın erişilebilir olması kontrol edilir.

Föydeki örnek zafiyet kaydı

Alan	Föy bilgisi
Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Bu kayıt föydeki eğitim senaryosudur; Component X'in veya bu CVE'nin VF-1D-A-696'da bulunduğuna dair kanıt değildir. Gerçek etkilenme için makineye ait SBOM ve üretici zafiyet bilgisi gerekir.

Görev - Karar akışı

1. Bu CVE bizi gerçekten etkiliyor mu?

Mevcut bilgilerle kesinleştirilemez. Makinenin SBOM'unda ilgili bileşen bulunur, sürümü CVE'den etkilenir ve açık erişilebilir durumdaysa sistem etkilenebilir.

2. Üretimi hemen durdurur musunuz? Neden?

Yalnızca föydeki CVSS 9.8 puanına dayanarak hemen durdurma kararı verilmez. Açığın makineye uygulanabilirliği ve fiziksel emniyete etkisi değerlendirilir; çalışan güvenliği tehdit altındaysa üretim durdurulur.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Yama önce izole test ortamında denenir. PLC, SCADA ve emniyet işlevlerine etkisi kontrol edilip gerekli geçerleme tamamlandıktan sonra uygulanır.

4. Bu yama safety validation'ı etkiliyor mu? Nasıl anlarsınız?

Etkileyebilir. SF1 güvenli erişim ve SF2 aşırı sıcaklık koruması, ilgili sensör-mantık-son eleman zinciriyle test edilerek doğru çalıştığı doğrulanır.

5. Yama mümkün değilse telafi edici önlem ne olur?

Etkilenen bileşen ağdan ayrılır, gereksiz bağlantılar kapatılır, bakım erişimi sınırlandırılır ve güvenlik duvarı kuralları sıkılaştırılır. Sistem izlenir ve risk yeniden değerlendirilir.

Kaynaklar

• INSPECCO × KRIPTARIUM, Genel LAB Föyleri: LAB 5, PDF s. 6.

• LAB 1 - SF1 ve SF2.

- LAB 2 - Bölgeler ve bağlantılar.
- LAB 3 - Tehdit ve risk.
- Siber risk kaydı.